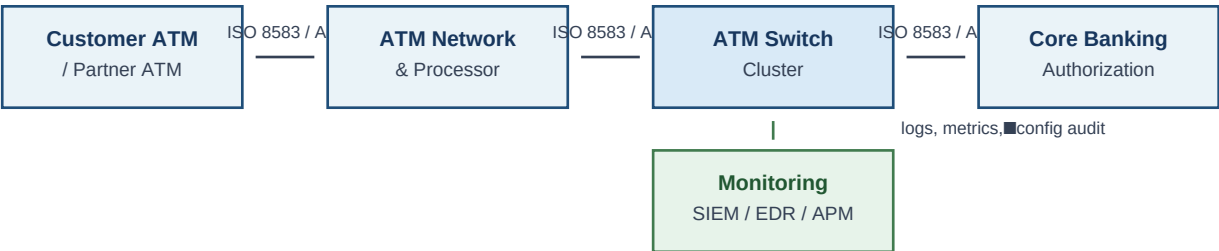


Cyber Tabletop Exercise

ATM Switch Outage and Cash Access Disruption

Improved facilitation-ready version with concrete cyber intrusion chain, observable evidence, recovery gates, and evidence-based MITRE ATT&CK mapping.



Exercise type	Facilitated tabletop exercise (TTX)
Recommended duration	120 minutes (90-minute compressed option included)
Audience	Executive leadership, crisis management, cyber/technology, ATM operations, branch/contact center, treasury, fraud, legal/compliance, communications, vendor management
Scenario classification	Internal use only
Scenario basis	Derived from the uploaded ATM switch TTX and revised using the uploaded evaluation feedback.

Facilitator intent

This exercise tests how the organization moves from a national ATM outage to a suspected cyber incident, makes safe restoration decisions under customer and liquidity pressure, and explains the incident without overclaiming facts.

Contents

1	1. Exercise overview and feedback integration
2	2. Exercise objectives
3	3. Scope, assumptions, and rules of engagement
4	4. Participant roles and governance model
5	5. Scenario environment and architecture assumptions
6	6. Concrete adversary path and technical timeline
7	7. Exercise timeline and inject cards
8	8. Decision points and expected good practices
9	9. Business, technical, customer, and regulatory impacts
10	10. Recovery validation and restoration gates
11	11. Debrief, after-action review, and improvement plan
12	12. Glossary
13	13. MITRE ATT&CK mapping
14	14. Source traceability

How to use this document

Facilitators should read sections 1-6 before the session, then use section 7 as the live inject script. Sections 8-13 support facilitation, scoring, debrief, and after-action reporting.

1. EXERCISE OVERVIEW AND FEEDBACK INTEGRATION

1. Exercise Overview

This tabletop exercise prepares participants to respond to a disruptive cyber incident affecting ATM transaction routing and customer cash access during a high-demand holiday weekend. The scenario begins as an operational outage and evolves into a suspected cyber incident once evidence of unauthorized remote access, configuration manipulation, and persistence is identified.

Purpose

- Exercise crisis coordination across cyber, technology, ATM operations, branch operations, contact center, treasury/liquidity, fraud, communications, legal/compliance, and executive leadership.
- Test the organization's ability to maintain customer access to cash while technical teams contain the incident and preserve evidence.
- Force explicit decisions about public statements, fee remediation, duplicate debit holds, emergency cash support, regulator engagement, vendor coordination, and safe reconnection.
- Validate technical containment and recovery prerequisites for ATM switch services before full restoration.

Feedback integration summary

Evaluation area	Improvement incorporated in this version
Realism	Added architecture assumptions, transaction-flow dependencies, vendor access model, specific operational constraints, monitoring signals, and cash/customer impacts.
Coherence and consistency	Defined an end-to-end causal chain from compromised vendor access through ATM switch configuration manipulation to national authorization timeouts and duplicate holds.
Cyber accuracy	Added initial access, execution, persistence, privilege escalation, credential access, discovery, lateral movement, C2, limited config exfiltration, defense evasion, and impact behaviors.
Training value	Added technical evidence, forensic ambiguity, containment tradeoffs, recovery gates, transaction-integrity validation, and role-specific expected actions.
Governance clarity	Clarified that SOC/technical incident command recommends or executes containment; crisis leadership owns business risk decisions, communications, customer treatment, and regulatory posture.

Scenario classification note

All organizations, assets, times, addresses, account names, indicators, and logs in this exercise are fictional. Use the organization's real procedures during the exercise, but do not treat the scenario as evidence of concern with a specific system, vendor, or employee.

2. EXERCISE OBJECTIVES

2. Exercise Objectives

By the end of the exercise, participants should be able to demonstrate the following capabilities.

Audience	Objectives
Executive / crisis leadership	Set severity and escalation; define risk appetite for emergency cash support and service restoration; approve customer and regulator-facing posture; maintain a common operating picture.
Operational / business	Manage branch overflow, contact-center surge, customer hardship cases, fee refunds, duplicate debit holds, cash logistics, and processor/vendor dependencies.
Technical / cyber	Classify cyber suspicion, preserve evidence, investigate privileged access anomalies, contain compromised access paths, validate switch configuration integrity, and define safe restoration gates.
Communications	Issue timely, empathetic, fact-based updates; distinguish service disruption from account compromise; prepare media, customer, employee, and partner messages.
Legal / compliance / risk	Assess notification thresholds, evidence preservation, customer harm, consumer protection issues, third-party obligations, and regulator-ready timelines.
Fraud / financial crime	Monitor for opportunistic scams, abnormal withdrawals, duplicate settlement issues, account takeover indicators, and fraud patterns during degraded service.

Primary exercise outcomes

- A documented incident command structure and escalation path for a national ATM disruption.
- A customer impact and remediation strategy that can be activated before complete root cause confirmation.
- A safe technical recovery plan based on evidence, clean configurations, credential rotation, and transaction-integrity checks.
- A regulator-ready preliminary timeline and after-action improvement plan.

3. SCOPE, ASSUMPTIONS, AND RULES OF ENGAGEMENT

3. Scope, Assumptions, and Rules of Engagement

In scope

- ATM withdrawals, balance inquiries, reversals, debit holds, and customer-facing ATM availability.
- ATM switch routing, authorization paths, service availability monitoring, and transaction queue integrity.
- Third-party and processor coordination, vendor remote access, and reconnection governance.
- Branch surge, contact-center scripts, customer hardship support, fee remediation, and cash logistics.
- SOC triage, technical containment, forensic preservation, privileged access review, configuration validation, and staged restoration.
- Customer, media, partner, regulator, board, and employee communications.

Out of scope

- Full malware reverse engineering or exploit development.
- Detailed jurisdiction-by-jurisdiction legal determinations.
- Vendor contract negotiation and financial settlement terms.
- Live testing against production systems.
- Attribution to a named threat actor or nation state.

Exercise assumptions

- The organization is a retail bank operating a national ATM fleet and depending on owned and partner ATM channels.
- The event occurs on a Friday before a long holiday weekend, with elevated cash demand and reduced staffing.
- Core banking remains operational, but ATM switch instability affects authorization, reversal processing, and customer confidence.
- A third-party ATM switch support provider has remote access through a controlled VPN and privileged access management process.
- Customer account balances are not believed compromised at exercise start; no customer PII exfiltration is confirmed in the scenario.
- Technical evidence is incomplete at first and evolves across injects.
- Participants should answer based on real roles, authorities, playbooks, and escalation thresholds.

Rules of engagement

- This is a no-fault learning exercise. The goal is to surface assumptions, dependencies, decisions, and improvement opportunities.
- There are no perfect answers. Facilitators should challenge premature certainty and encourage evidence-based decision making.
- Real incidents take precedence over the exercise.
- Do not fight the scenario. Treat the facts provided in each inject as true for the purpose of discussion.
- Use plain language when explaining technical issues to business stakeholders and customers.
- Maintain a decision log: decision, owner, time, rationale, assumptions, and follow-up action.

4. PARTICIPANT ROLES AND GOVERNANCE MODEL

4. Participant Roles and Governance Model

Role / function	Primary responsibilities during the exercise
Executive sponsor / crisis lead	Own business-level crisis decisions, severity escalation, customer risk appetite, public posture, board updates, and cross-functional alignment.
Cyber incident commander / SOC	Triage cyber evidence, coordinate containment, preserve evidence, direct endpoint/network actions, and provide technical risk recommendations.
ATM switch service owner	Assess service health, configuration integrity, routing state, rollback options, and restoration readiness.
Infrastructure / network operations	Validate network paths, firewall changes, VPN sessions, privileged access paths, segmentation, and C2 blocking.
Payments / ATM operations	Assess transaction failure rates, processor status, reversals, duplicate debit holds, settlement backlog, and service prioritization.
Branch operations	Manage customer queues, security risks, cash limits, branch staffing, and exception handling.
Contact center / customer operations	Issue scripts, manage surge, triage vulnerable customers, track complaints, and feed customer signals into the common operating picture.
Treasury / liquidity	Assess emergency cash support, branch cash replenishment, ATM replenishment priorities, and liquidity implications.
Fraud operations	Monitor suspicious withdrawals, scams exploiting the outage, account takeover signals, and abnormal card behavior.
Communications	Draft and publish customer, employee, media, partner, and social updates approved through crisis governance.
Legal / compliance / privacy	Advise on notification thresholds, evidence preservation, privilege, customer harm, regulator engagement, and privacy assessment.
Vendor / processor management	Coordinate with the ATM switch provider, processor, managed service partners, and third-party risk teams.

Governance principle

Clear ownership

The SOC and technical incident commander own technical containment recommendations and evidence handling. Crisis leadership owns business-risk decisions such as emergency cash limits, customer remediation, external messaging, and regulator engagement. Neither group should make the other's decision in isolation.

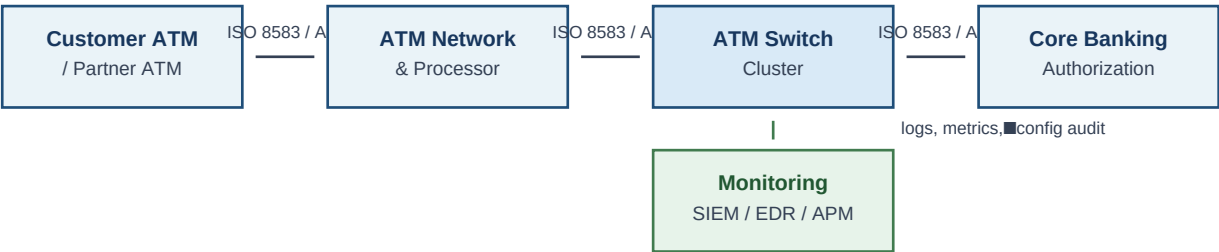
Key decisions and authorities

Decision	Recommended owner	Required input
Declare crisis / major incident	Crisis lead	SOC, ATM operations, customer operations, risk
Disconnect vendor remote access	SOC / technical incident commander	Network, third-party risk, legal, service owner
Enable emergency cash support	Executive crisis lead	Treasury, branch ops, fraud, legal, customer ops
Public statement content	Communications lead	Legal, crisis lead, SOC, customer ops
Regulator notification	Legal/compliance lead	Crisis lead, SOC, risk, privacy
Authorize reconnection / restoration	Joint: technical incident commander and business service owner	SOC, ATM switch owner, processor, risk, crisis lead
Close incident / transition to BAU	Crisis lead	All workstream leads

5. SCENARIO ENVIRONMENT AND ARCHITECTURE ASSUMPTIONS

5. Scenario Environment and Architecture Assumptions

The exercise uses a simplified but realistic ATM switch environment. Facilitators may adapt names and dependencies to match the organization before delivery.



Critical service flow

- 1
- A customer initiates a withdrawal or balance inquiry at an owned or partner ATM.
- 2
- The ATM network and processor route the request to the bank's ATM switch service.
- 3
- The ATM switch validates routing rules, card/product eligibility, processor path, and authorization dependencies.
- 4
- Core authorization confirms available balance and returns approval or decline.
- 5
- The ATM switch relays the response and records transaction state for reversals, settlement, monitoring, and exception handling.
- 6
- Monitoring tools collect switch health, transaction failure rates, timeout rates, queue depth, config audit events, EDR alerts, and network flow telemetry.

Architecture assumptions for this exercise

Component	Exercise assumption
ATM switch cluster	Two active nodes and one standby node support national transaction routing. Configuration changes are replicated through a management service.
Admin jump host	Privileged administrators and vendor support accounts access the switch management tier through a segmented jump host with MFA and PAM approval.
Vendor access	A third-party ATM switch support provider has limited remote access during maintenance windows. Access is logged but not always correlated with change tickets in real time.
Processor link	The processor is external and sees authorization timeouts and duplicate/retry messages but does not control bank-side switch configuration.
Core banking	Core banking and customer balance systems remain available; customer impact comes from ATM switch routing failures and reversal delays.
Monitoring	SIEM, EDR, application performance monitoring, transaction monitoring, and configuration audit logs exist but are operated by different teams.
Known weakness	An older maintenance script on the admin jump host stores an encrypted service credential that can be misused if local administrator privileges are obtained.

Normal baseline indicators

- ATM authorization failure rate below 0.5 percent nationally.
- Timeout rate below 0.3 percent across primary processor path.
- No switch configuration change outside approved maintenance windows.
- Vendor remote access only during approved tickets and from expected geographies.
- No unusual outbound HTTPS from the admin jump host to unapproved cloud infrastructure.
- Duplicate hold exceptions handled in small daily batches, not national surge volumes.

6. CONCRETE ADVERSARY PATH AND TECHNICAL TIMELINE

6. Concrete Adversary Path and Technical Timeline

Scenario design choice

The original exercise appropriately avoided overclaiming. This improved version makes an explicit training assumption: the outage is caused by a compromised third-party remote access path and malicious ATM switch configuration manipulation. Customer account data compromise is not confirmed.



Exercise assumption: no confirmed customer account takeover or PII exfiltration at start; evidence evolves by inject.

Threat scenario summary

An adversary compromises a third-party support account used by the ATM switch provider. The account is used to access the bank's vendor VPN and ATM administration jump host outside a normal maintenance window. After discovery and credential access, the adversary obtains a switch service credential from a maintenance script, uses remote administration to reach switch management nodes, modifies routing and retry configuration, stops one routing adapter service, and creates a scheduled task to reapply the malicious configuration. The result is a national spike in ATM authorization timeouts, repeated reversal messages, and duplicate debit holds.

Adversary timeline for facilitators

Relative time	Adversary / system activity	Observable evidence
T-10 days	Third-party support user's credentials and session token are stolen through an adversary-in-the-middle phishing page.	Vendor later reports suspicious login to its identity provider. Bank sees no direct evidence yet.
T-3 days	Valid vendor VPN access is used from an unusual cloud ASN. The adversary lands on the ATM admin jump host.	VPN login from 203.0.113.47; MFA approval present but no matching vendor ticket.
T-2 days	The adversary performs discovery of switch management servers, service accounts, route profiles, and processor endpoint names.	PowerShell 4104 logs with directory enumeration; DNS queries for switch-admin and route-node hosts.
T-1 day	Credential material is found in a maintenance script and used to access the switch management service account.	File access to maintenance scripts; PAM checkout not recorded for the account actually used.
Friday 03:12	Routing profile is altered: processor priority, heartbeat timeout, retry thresholds, and reversal behavior are changed.	Configuration audit delta; no approved change ticket; service config hash mismatch.
Friday 03:20	A scheduled task is created to reapply the altered configuration every 20 minutes.	Windows Task Scheduler event and EDR suspicious persistence alert.
Friday 06:45	ATM authorization timeouts begin to exceed normal thresholds as holiday cash demand increases.	APM alerts; processor sees unusual timeout/retry patterns.
Friday 08:00	Customer impact becomes visible nationally.	Branch calls, social complaints, failed withdrawals, duplicate debit holds.
Friday 10:00	SOC identifies anomalous vendor remote access and suspicious PowerShell activity.	SIEM correlation: VPN, EDR, config audit, and ATM failure metrics.
Friday 14:00	Containment reveals persistence and outbound HTTPS beaconing from the admin jump host.	Firewall/proxy logs to 198.51.100.27; scheduled task reverts a manual fix.
Saturday 09:00	Clean configuration is restored to standby node after credential rotation and integrity validation.	Failure rate trends down; transaction queues and reversals require cleanup.

Evidence package by technical stage

Stage	Evidence available to participants	Containment or decision trigger
Initial access	Vendor VPN login from unusual IP; no matching change ticket; support provider cannot initially confirm legitimacy.	Suspend vendor VPN session and require out-of-band vendor validation.
Execution	EDR flags encoded PowerShell and remote command execution from the jump host.	Preserve host image; restrict interactive admin sessions; review command history.
Credential access	Access to script containing service credential material; unusual use of service account outside automation window.	Rotate service credentials; invalidate tokens; review PAM logs and secrets storage.
Discovery / lateral movement	Network flows from jump host to switch nodes; WinRM activity; enumeration of routing configuration shares.	Limit management traffic to approved admin hosts; isolate jump host if safe.
Persistence	Scheduled task named SwitchHealthSync created outside change window and reapplying altered config.	Disable malicious task; confirm no additional persistence before recovery.
C2 / exfiltration	Outbound HTTPS from admin host to unapproved cloud IP; small archive of routing config and logs staged.	Block egress; capture artifacts; privacy and data exposure assessment.
Impact	Routing config hash mismatch; route adapter service stopped on one node; national authorization timeout and duplicate hold surge.	Rollback from known-good config; staged recovery with processor validation.

7. EXERCISE TIMELINE AND INJECT CARDS

7. Exercise Timeline and Inject Cards

Suggested pacing

Segment	120-minute session	90-minute option
Introduction, objectives, rules	10 minutes	7 minutes
Architecture and scenario context	10 minutes	6 minutes
Inject 1 - National outage discovery	15 minutes	12 minutes
Inject 2 - Cyber suspicion and vendor access	20 minutes	15 minutes
Inject 3 - Containment, liquidity, and public trust	25 minutes	18 minutes
Inject 4 - Controlled restoration	20 minutes	15 minutes
Inject 5 - Post-incident obligations	10 minutes	7 minutes
Debrief and lessons learned	10 minutes	10 minutes

Facilitators may omit Inject 5 in a compressed executive session and cover post-incident obligations during the debrief.

INJECT 1: NATIONAL SPIKE IN FAILED WITHDRAWALS

Inject 1 - National spike in failed withdrawals

Simulated time	Friday, 08:00
Elapsed time	Incident discovery

Inject

Customers across multiple regions report failed ATM withdrawals, balance inquiry failures, and duplicate debit holds after unsuccessful transactions. Branch call volumes and social media complaints surge. Internal monitoring shows ATM authorization failure rates increasing from a normal baseline below 0.5 percent to 38 percent nationally, with repeated timeout conditions in the ATM switch service.

What participants know

- Failures are national rather than isolated to one region or ATM vendor.
- Some customers see temporary debit holds despite failed withdrawals.
- Branches are beginning to receive overflow traffic.
- Core banking appears available for online and mobile balance viewing.
- The root cause is unknown and initially treated as a major service outage.

Technical evidence provided

- ATM switch APM dashboard: authorization timeouts and reversal queue depth above threshold.
- Processor operations call: processor is receiving abnormal retry and reversal patterns from the bank side.
- No confirmed malware alert yet; no confirmed data loss.
- ServiceNow ticket opened as P1 technology incident with cyber watch requested.

Discussion questions

- 1 How is the incident initially classified and who owns command?
- 2 What threshold activates crisis management and executive notification?
- 3 What facts are needed in the first 30 minutes to establish customer, operational, technical, and liquidity impact?
- 4 What customer-facing channels need rapid updates before root cause is known?
- 5 How will the bank handle duplicate holds, fees, and hardship cases from the outset?
- 6 What branch and contact-center surge actions are needed immediately?

Expected actions

- Open and triage a high-severity incident with a decision log and single operating picture.
- Confirm impact by channel, region, transaction type, partner ATM, and customer segment.
- Notify cyber incident command, ATM operations, branch operations, contact center, treasury, fraud, legal/compliance, communications, and executive leadership.
- Prepare customer service guidance that acknowledges symptoms without speculating on cause.
- Start duplicate hold tracking and fee-remediation planning.
- Request processor and vendor status and confirm whether any approved maintenance or changes occurred.

Facilitator notes

Facilitator guidance

Push participants to separate facts from assumptions. The correct posture is not to declare a cyberattack immediately, but to involve cyber early because national transaction-routing anomalies and duplicate holds may indicate integrity or availability manipulation. Challenge whether business continuity playbooks cover a national ATM outage during a holiday weekend.

Observation confidence rating

At the end of this inject, ask participants to rate confidence from 1 (not confident) to 5 (fully confident):

- We can classify and escalate a national ATM outage quickly and consistently.
- We can produce a reliable customer impact picture across ATM, branch, contact center, and processor data.
- We have immediate customer scripts for failed withdrawals and duplicate debit holds.

INJECT 2: CYBER SUSPICION INTENSIFIES THROUGH VENDOR ACCESS ANOMALY

Inject 2 - Cyber suspicion intensifies through vendor access anomaly

Simulated time	Friday, 10:15
Elapsed time	2 hours 15 minutes after discovery

Inject

SOC correlation identifies a vendor VPN login to the ATM administration jump host at 02:17 from an unusual cloud-hosted IP address. The access used a valid third-party support account, but there is no approved maintenance ticket. EDR also records PowerShell activity on the jump host shortly before the ATM switch configuration changed at 03:12.

What participants know

- The incident is now treated as a suspected cyber-related service disruption.
- The vendor cannot immediately validate that the 02:17 access was legitimate.
- ATM failures continue nationally and call-center wait times are rising sharply.
- Media inquiries ask whether the outage is cyber-related and whether customer balances are safe.
- No confirmed customer account compromise or PII exfiltration exists at this stage.

Technical evidence provided

- VPN log: vendor-support-17 authenticated from 203.0.113.47 outside normal geographies.
- PowerShell log: configuration directory enumeration and archive creation on the admin jump host.
- Configuration audit: route profile hash changed at 03:12 with no change ticket.
- Outbound proxy: low-volume HTTPS from jump host to 198.51.100.27.
- PAM: no privileged access request corresponding to the configuration change.

Discussion questions

- 1 Who has authority to suspend vendor remote access and isolate the jump host?
- 2 What business risks arise if containment actions slow restoration?
- 3 What evidence must be preserved before disabling accounts, isolating systems, or rolling back configuration?
- 4 What should the first public statement say, and what should it avoid?
- 5 When should regulators, payment partners, sector coordination groups, law enforcement, or cyber insurance contacts be notified?
- 6 How should the bank explain the difference between ATM service disruption and account balance compromise?

Expected actions

- Move to cyber incident governance while maintaining business crisis management.
- Disable or suspend the suspicious vendor session and require out-of-band vendor validation.
- Preserve logs and images for the jump host, VPN, EDR, switch configuration repository, processor telemetry, and PAM records.
- Begin credential rotation planning for affected service and vendor accounts.
- Approve an initial customer statement that is transparent about service impact and avoids unsupported cyber attribution.
- Define interim customer remediation principles and emergency cash support thresholds.

Facilitator notes

Facilitator guidance

Probe the boundary between SOC decisions and crisis-cell decisions. SOC can recommend or execute technical containment under protocol, while crisis leadership must own customer impact, communications, cash access, and regulatory posture. Encourage precise wording: suspected unauthorized access, no evidence of customer balance compromise, investigation ongoing.

Observation confidence rating

At the end of this inject, ask participants to rate confidence from 1 (not confident) to 5 (fully confident):

- We can suspend third-party access without losing evidence or vendor coordination.
- We understand who approves customer, regulator, and media statements during cyber uncertainty.
- We can distinguish a service availability incident from a confirmed data breach in communications.

INJECT 3: CONTAINMENT TRADEOFF, EMERGENCY CASH, AND PERSISTENCE DISCOVERED

Inject 3 - Containment tradeoff, emergency cash, and persistence discovered

Simulated time	Friday, 14:00
Elapsed time	6 hours after discovery

Inject

The ATM switch service owner attempts to restore the previous routing profile, but the configuration reverts within 20 minutes. SOC identifies a scheduled task named SwitchHealthSync on the admin jump host that appears to reapply altered routing parameters. A route adapter service is also stopped on one switch node. Branches report rising confrontational customer interactions, and the contact center is exceeding service-level targets.

What participants know

- The outage is now strongly suspected to be caused by malicious configuration manipulation.
- The impact is availability and transaction-integrity related; no customer PII exfiltration is confirmed.
- Restoration may require isolation of the management tier, service credential rotation, and recovery from a known-good configuration.
- Public rumors are increasing, including claims that customer balances have disappeared.
- Several branches request guidance on emergency cash withdrawal limits and security support.

Technical evidence provided

- Windows scheduled task created at 03:20 outside maintenance window.
- Service control event: ATMRouteAdapter stopped on switch-node-02.
- Switch config diff: heartbeat timeout reduced, processor endpoint priority altered, retry threshold changed.
- Small archive containing routing config and application logs staged in a temp directory.
- Outbound HTTPS beaconing blocked after firewall change; no evidence of bulk customer data transfer.

Discussion questions

- 1 Do you isolate the ATM switch management tier now, even if this delays restoration?
- 2 What minimum evidence is needed before declaring the event a confirmed cyber incident?
- 3 What are the recovery prerequisites before reconnecting or normalizing ATM switch functions?
- 4 Who decides emergency cash limits, vulnerable-customer support, fee waivers, and branch security measures?
- 5 How do fraud and scam monitoring change while customers are frustrated and seeking cash?
- 6 What is the weekend operating model if restoration is delayed?

Expected actions

- Disable malicious scheduled task and confirm no additional persistence on jump host and switch nodes.
- Rotate vendor, admin, and service credentials used in the ATM switch management path.
- Isolate or rebuild the jump host as needed while preserving forensic evidence.
- Restore configuration only from a validated baseline repository and require dual approval.
- Activate branch and contact-center surge plans, hardship support, security escalation, and fraud monitoring.
- Issue updated messaging that confirms a suspected cyber-related service disruption without overstating account compromise.

Facilitator notes

Facilitator guidance

This is the main decision-pressure inject. Force tradeoff discussion: fast restoration from a possibly compromised path versus slower restoration through a clean administrative path. Push for explicit recovery gates: identity clean-up, persistence removal, config integrity, processor validation, transaction queue reconciliation, and heightened monitoring.

Observation confidence rating

At the end of this inject, ask participants to rate confidence from 1 (not confident) to 5 (fully confident):

- We can make containment decisions that balance safety, availability, evidence, and customer harm.
- We have workable emergency cash and branch-surge procedures for a prolonged national outage.
- Technical teams can translate recovery gates into business language that executives can approve.

INJECT 4: CONTROLLED RESTORATION AND TRANSACTION INTEGRITY VALIDATION

Inject 4 - Controlled restoration and transaction integrity validation

Simulated time	Saturday, 09:00
Elapsed time	25 hours after discovery

Inject

The processor confirms that external connectivity is stable. The bank's cyber and technology teams have blocked the suspicious outbound destination, disabled compromised access, rotated key credentials, rebuilt the admin jump host from a clean image, and restored a known-good switch configuration to the standby node. Full reconnection and normalization still require validation. Transaction backlogs, duplicate holds, customer complaints, fee reversals, and branch cash replenishment issues remain active.

What participants know

- Core disruption conditions are improving, but customer remediation remains significant.
- The clean standby node passes initial health checks in a controlled test group.
- The service owner requests approval for staged national restoration.
- Executives request a preliminary impact summary and regulator-ready timeline.
- Contact center and branch teams still need scripts for customers affected by holds and fees.

Technical evidence provided

- EDR shows no new suspicious activity on rebuilt admin host.
- Known-good config hash matches baseline repository and dual approval record.
- Processor test transactions succeed across withdrawal, balance inquiry, reversal, and decline cases.
- Transaction queue depth remains above normal; duplicate debit hold exception queue requires reconciliation.
- No evidence of HSM key access or core banking administrator compromise.

Discussion questions

- 1 Who authorizes staged restoration and what are the approval gates?
- 2 What validation proves transaction integrity, not just service availability?
- 3 What monitoring thresholds determine whether to continue, pause, or roll back restoration?
- 4 How will backlog processing, duplicate hold reversals, fee refunds, and customer complaints be managed?
- 5 What communications are needed to close the customer-impact loop without implying the incident is fully closed?
- 6 What must be included in the preliminary executive and regulator timeline?

Expected actions

- Execute staged restoration by region, transaction type, or ATM group with predefined rollback criteria.
- Validate withdrawal, balance inquiry, reversal, duplicate hold, settlement, and reconciliation integrity.
- Monitor authorization failure rate, timeout rate, queue depth, reversal mismatch, fraud alerts, and customer complaint rate.
- Publish recovery communications with remediation steps, expected hold reversal timing, and contact channels.
- Prepare preliminary timeline, impacted services, containment actions, customer harm assessment, and next steps for regulators.
- Assign owners for continued remediation and after-action review.

Facilitator notes

Facilitator guidance

Emphasize that technical service restoration is not the same as incident closure. Customer trust, transaction integrity, regulatory reporting, vendor accountability, and lessons learned continue. Ask teams to define measurable restoration criteria rather than relying on subjective comfort.

Observation confidence rating

At the end of this inject, ask participants to rate confidence from 1 (not confident) to 5 (fully confident):

- We have clear technical and business criteria for safe reconnection.
- We can validate transaction integrity after a switch configuration manipulation scenario.
- We can manage customer remediation after service availability returns.

INJECT 5: POST-INCIDENT OBLIGATIONS AND RESILIENCE IMPROVEMENT

Inject 5 - Post-incident obligations and resilience improvement

Simulated time	Monday, 10:00
Elapsed time	First business day after weekend restoration

Inject

ATM availability has returned to normal levels. Customer complaints and duplicate hold remediation continue, and the regulator has requested a written preliminary incident report. The vendor confirms that one of its support users was phished and that its account was used to access the bank's environment. The board requests a concise summary of business impact, cyber root cause, customer treatment, and resilience improvements.

What participants know

- The incident is no longer actively disrupting ATM services.
- The root cause is assessed as compromised third-party remote access plus malicious ATM switch configuration changes.
- No customer PII exfiltration has been confirmed, but routing configuration and logs were likely staged and transferred.
- Customer remediation, complaint handling, vendor review, and monitoring will continue.
- A formal after-action review is required.

Technical evidence provided

- Final config diff and access timeline are available for preliminary reporting.
- Vendor identity-provider logs align with bank VPN and EDR evidence.
- No further C2 traffic or unauthorized vendor access is observed.
- Duplicate hold exception queue is 80 percent cleared; remaining cases require manual review.
- Fraud monitoring shows elevated phishing/scam attempts using the outage as a lure.

Discussion questions

- 1 What must be reported to regulators, the board, and senior management?
- 2 What customer remediation metrics should remain under daily oversight?
- 3 How should third-party risk, vendor access, PAM, and segmentation controls change?
- 4 What improvements are needed in monitoring, change control, and transaction-integrity validation?
- 5 Who owns the after-action improvement plan and by when will actions be tracked?
- 6 What would have changed if customer PII or account compromise had been confirmed?

Expected actions

- Deliver preliminary regulator and board summaries with facts, assumptions, impact, containment, recovery, and next steps.
- Maintain heightened monitoring for fraud, C2, vendor access, switch configuration changes, and customer complaints.
- Open corrective actions for third-party access controls, MFA, PAM enforcement, jump-host hardening, secrets storage, alert correlation, and DR validation.
- Complete customer remediation and track complaints to closure.
- Schedule after-action review and assign accountable owners, target dates, and risk acceptance decisions.

Facilitator notes

Facilitator guidance

Use this inject to convert exercise findings into durable improvements. Do not let participants stop at generic lessons learned. Require owners, dates, control changes, testing cadence, and executive visibility.

Observation confidence rating

At the end of this inject, ask participants to rate confidence from 1 (not confident) to 5 (fully confident):

- We can produce regulator-ready and board-ready incident narratives from technical and business facts.
- We can turn lessons learned into owned, dated, risk-prioritized improvement actions.
- We understand how third-party access control weaknesses contributed to the incident.

8. DECISION POINTS AND EXPECTED GOOD PRACTICES

8. Decision Points and Expected Good Practices

Core decision points

Decision point	Expected decision output
Incident classification	Major technology incident with cyber watch at discovery; suspected cyber incident after vendor access anomaly; confirmed cyber incident after malicious config/persistence evidence.
Crisis activation	Clear threshold and owner for activating crisis management, executive sponsor, workstream leads, and decision log.
Vendor access containment	Suspend suspicious sessions, validate with vendor out-of-band, preserve evidence, and define exception process for support access.
Customer communications	Plain-language updates that acknowledge impact, avoid unsupported root-cause claims, explain account-balance status, and provide remediation channels.
Emergency cash support	Limits, eligibility, approval authority, vulnerable-customer support, fraud controls, and branch security measures.
Regulator engagement	Decision matrix for when to notify, what facts are known, what remains under investigation, and who owns follow-up.
Technical restoration	Staged reconnection only after credentials, persistence, configuration, processor testing, transaction integrity, and monitoring gates are satisfied.
Incident closure	Close only after technical stability, customer remediation path, regulatory response, evidence preservation, and after-action ownership are established.

Expected good practices

- Use a single common operating picture covering customer impact, technical facts, decisions, open risks, and next updates.
- Preserve evidence before irreversible containment when business impact allows.
- Separate confirmed facts from working hypotheses in all communications.
- Protect customer access to cash while managing fraud, staff safety, and liquidity risk.
- Do not restore from a compromised administrative path or unvalidated configuration.
- Use dual approval for switch configuration rollback and reconnection.
- Translate technical restoration gates into executive-level risk language.
- Track customer remediation through closure, not only technical recovery.
- Escalate third-party risk and vendor control failures into an accountable remediation plan.

Facilitator assessment rubric

Capability	1 - Low maturity	3 - Developing	5 - Strong
Governance	Unclear owner; parallel conversations; no decision log.	Owners identified but escalation and decision rights require prompting.	Clear command structure, decision log, cadence, and escalation.
Cyber triage	Cyber suspicion discussed without evidence or containment plan.	Evidence reviewed, but mapping to containment and recovery is incomplete.	Evidence-driven classification, containment, preservation, and recovery gates.
Customer response	Reactive messaging; no remediation model.	Basic scripts and remediation discussed.	Timely, empathetic, measurable customer support and remediation.
Operational resilience	Workarounds unclear or unrealistic.	Workarounds available but capacity/ownership not fully defined.	Prioritized, resourced workarounds with clear limits and escalation.
Restoration governance	Restores service before root containment and validation.	Some validation gates but incomplete rollback criteria.	Staged, measurable, jointly approved restoration with rollback criteria.
After-action	Generic lessons learned.	Findings recorded but weak ownership.	Risk-ranked actions with owners, dates, validation method, and executive visibility.

9. BUSINESS, TECHNICAL, CUSTOMER, AND REGULATORY IMPACTS

9. Business, Technical, Customer, and Regulatory Impacts

Impact category	Scenario impacts	Key controls or responses
Customer	Failed withdrawals, duplicate debit holds, uncertainty about balances, hardship cases, branch queues, increased complaints.	Plain-language updates, fee waivers, duplicate hold remediation, vulnerable customer process, complaint tracking.
Branch / operations	Overflow traffic, staff pressure, security concerns, cash replenishment pressure, exception handling.	Branch surge plan, cash limits, staff scripts, security escalation, daily branch status calls.
Contact center	High wait times, inconsistent answers, repeat callers, vulnerable customer escalations.	Approved scripts, callback options, IVR banner, priority queues, escalation path to remediation team.
Treasury / liquidity	Potential emergency cash support and ATM replenishment prioritization during holiday demand.	Cash forecasting, branch cash caps, partner ATM decisions, executive thresholds.
Technology	Switch routing instability, route adapter service stop, config drift, queue backlog, reconciliation complexity.	Configuration rollback, credential rotation, clean admin path, processor tests, transaction-integrity checks.
Cyber	Compromised vendor access, suspicious PowerShell, persistence, outbound beaconing, limited config/log exfiltration.	VPN suspension, endpoint isolation, evidence preservation, C2 block, secrets review, monitoring.
Fraud	Scams exploiting outage, abnormal withdrawal behavior, duplicate/reversal manipulation attempts.	Heightened fraud rules, customer warnings, social monitoring, account takeover monitoring.
Legal / regulatory	Operational resilience scrutiny, customer harm, third-party control failure, potential cyber reporting obligations.	Regulator-ready timeline, breach assessment, legal privilege process, board reporting, third-party review.
Reputation	Visible national cash-access disruption during holiday weekend and social/media amplification.	Frequent updates, customer-first remediation, executive messaging, clear closure criteria.

Customer treatment principles

- Acknowledge inconvenience and anxiety without minimizing impact.
- Prioritize vulnerable customers and urgent cash needs.
- Waive fees and reverse duplicate holds according to approved remediation principles.
- Avoid asking customers to repeatedly prove the same failed transaction if bank data can validate it.
- Provide realistic update cadence and explain what services are available.
- Monitor scams that reference the outage and warn customers not to share credentials or one-time passcodes.

10. RECOVERY VALIDATION AND RESTORATION GATES

10. Recovery Validation and Restoration Gates

The group should explicitly define what 'safe to restore' means. Service availability alone is insufficient after suspected manipulation of routing configuration and privileged access.

Gate	Minimum evidence required	Owner
Access containment	Suspicious vendor sessions terminated; affected accounts disabled or reset; tokens revoked; MFA and PAM records reviewed.	SOC / IAM / vendor management
Evidence preservation	VPN, EDR, system, switch, configuration audit, processor, PAM, proxy, and SIEM records preserved.	SOC / legal / technology
Persistence removed	Scheduled task and unauthorized services removed; clean rebuild or isolation of admin jump host completed.	SOC / endpoint / infrastructure
Credential hygiene	Vendor, administrator, and switch service credentials rotated; secrets removed from scripts; emergency break-glass controlled.	IAM / service owner
Configuration integrity	Known-good routing profile restored from baseline; hash validated; dual approval recorded; drift monitoring active.	ATM switch owner / change manager
Processor validation	Withdrawal, balance inquiry, reversal, decline, timeout, and partner ATM test cases validated with processor.	ATM operations / processor liaison
Transaction integrity	Duplicate debit holds, reversals, settlement queues, and exception queues reconciled or controlled.	Payments operations / finance
Monitoring readiness	Failure rate, timeout rate, queue depth, EDR, C2 egress, config drift, fraud, and complaint thresholds defined.	SOC / APM / fraud / customer ops
Business approval	Residual risk accepted or mitigated; customer, branch, treasury, legal, and communications impacts addressed.	Crisis lead / service owner
Rollback plan	Criteria, owner, communication path, and technical steps for rollback agreed before each restoration wave.	Technical incident commander

Staged restoration model

- 1 Restore a limited test group of owned ATMs with processor monitoring in place.
- 2 Validate successful withdrawals, balance inquiries, reversals, and declined transactions.
- 3 Expand by region or ATM group only if failure and timeout rates remain below agreed thresholds.
- 4 Pause expansion if duplicate hold volume, route-adaptor failures, config drift, or EDR alerts recur.
- 5 Do not close the incident until customer remediation, reporting, and monitoring workstreams have named owners.

11. DEBRIEF, AFTER-ACTION REVIEW, AND IMPROVEMENT PLAN

11. Debrief, After-Action Review, and Improvement Plan

Debrief questions

- 1 What worked well in the first 60 minutes?
- 2 Where did classification, escalation, or decision rights appear unclear?
- 3 Were technical teams able to explain cyber evidence and recovery gates in business terms?
- 4 Could the organization support emergency cash access during a national holiday-weekend outage?
- 5 Were customer communications timely, empathetic, and precise about what was known and unknown?
- 6 Did the restoration process appropriately balance speed, safety, evidence preservation, and customer harm?
- 7 Were third-party access controls, monitoring, and vendor communications sufficient?
- 8 What would have changed if customer PII exfiltration or account takeover had been confirmed?
- 9 Which improvement actions require executive funding, risk acceptance, or policy change?

Potential improvement themes

- ATM switch cyber disruption playbook with business and technical workstreams.
- Third-party remote access governance, MFA controls, PAM enforcement, vendor session monitoring, and out-of-band verification.
- Secrets management and removal of credentials from maintenance scripts.
- Configuration baseline, drift detection, dual approval, and rollback testing for switch services.
- Correlation of VPN, PAM, EDR, configuration audit, processor telemetry, and customer impact signals.
- Duplicate hold, reversal, fee-remediation, and complaint-handling workflows.
- Emergency cash support model, branch surge staffing, branch security, and vulnerable-customer support.
- Regulator and board reporting templates for cyber-related operational resilience incidents.
- Staged recovery and transaction-integrity validation for payment-routing services.
- Fraud and scam monitoring playbook during highly visible service disruptions.

After-action tracker template

Finding	Risk / impact	Owner	Due date	Validation method	Status
Example: vendor VPN access not correlated with change tickets in real time	Unauthorized support access may remain undetected until customer impact	IAM / SOC / third-party risk	T+60 days	Alert test with simulated vendor login outside ticket window	Open
Example: switch config rollback requires manual cross-team coordination	Restoration delay and inconsistent approval evidence	ATM switch owner	T+45 days	Tabletop plus technical rollback test	Open
Example: customer duplicate hold script not pre-approved	Inconsistent customer treatment and reputational harm	Customer operations / legal	T+30 days	Script approval and call-center exercise	Open

12. GLOSSARY

12. Glossary

Term	Definition
ATM switch	Service layer that routes ATM transactions to authorization paths, manages responses, and supports availability and transaction-state monitoring.
Authorization timeout	A transaction condition where the authorization response is not received within expected time, often leading to customer-facing failure or retry behavior.
Duplicate debit hold	A temporary hold that appears after an attempted transaction fails or is retried, requiring reversal or reconciliation.
EDR	Endpoint Detection and Response tooling used to detect and investigate suspicious endpoint behavior.
PAM	Privileged Access Management process or tooling used to authorize, monitor, and control privileged sessions and credential checkout.
Processor	External payment or ATM network processor that routes or supports ATM transaction processing.
Reversal	A transaction message used to cancel or correct a prior authorization when a withdrawal fails or cannot complete.
SIEM	Security Information and Event Management platform that correlates logs and security alerts.
C2	Command and Control communication path used by an adversary to issue commands or receive results from compromised systems.
Known-good configuration	A validated baseline configuration that is approved, integrity-checked, and suitable for restoration.
Staged restoration	Controlled recovery in limited waves with defined monitoring thresholds and rollback criteria.
Common operating picture	A shared incident view covering facts, assumptions, impact, decisions, owners, and next updates.

13. MITRE ATT&CK MAPPING

13. MITRE ATT&CK Mapping

The mapping below is evidence-based for this improved exercise version. Techniques are mapped only where a scenario behavior or artifact explicitly supports the mapping. The exercise intentionally does not assert customer account takeover or bulk customer PII exfiltration.

Tactic	Technique / sub-technique	Scenario behavior	Evidence in exercise	Discussion / detection focus
Initial Access (TA0001)	T1199 - Trusted Relationship T1078 - Valid Accounts	Compromised third-party support account used to access bank vendor VPN.	VPN login from unusual cloud IP; valid MFA; no matching maintenance ticket.	Third-party access validation, vendor identity logs, MFA strength, PAM correlation.
Execution (TA0002)	T1059.001 - PowerShell	PowerShell used on ATM admin jump host for enumeration and archive staging.	PowerShell logging and EDR alert.	Script block logging, constrained language mode, admin host monitoring.
Persistence (TA0003)	T1053.005 - Scheduled Task	Scheduled task created to reapply altered switch configuration.	SwitchHealthSync task created outside maintenance window.	Task creation alerts and change window correlation.
Privilege Escalation / Credential Access (TA0004 / TA0006)	T1552.001 - Credentials In Files T1078 - Valid Accounts	Adversary obtains service credential material from maintenance script and uses the service account.	File access to maintenance script; service account use outside automation window.	Secrets scanning, service account restrictions, PAM enforcement.
Defense Evasion (TA0005)	T1070.001 - Clear Windows Event Logs T1562.001 - Impair Defenses	Partial clearing of local logs and attempted suppression of endpoint telemetry on admin host.	Gaps in local logs; EDR tamper alert.	EDR tamper protection, central log forwarding, alert on log clearing.
Discovery (TA0007)	T1016 - System Network Configuration Discovery T1046 - Network Service Discovery	Enumeration of switch management hosts, routing shares, and processor endpoints.	DNS, PowerShell, and network connection telemetry.	Baseline admin behavior and alert on unexpected discovery commands.
Lateral Movement (TA0008)	T1021.001 - Remote Desktop Protocol T1021.006 - Windows Remote Management	Movement from vendor VPN and jump host to switch management nodes.	RDP/WinRM flows from jump host to switch nodes.	Segmentation, privileged access, and session recording.
Command and Control (TA0011)	T1071.001 - Web Protocols	Outbound HTTPS from admin jump host to unapproved cloud infrastructure.	Proxy/firewall logs to 198.51.100.27.	Egress allowlisting, proxy inspection, anomaly detection.
Exfiltration (TA0010)	T1041 - Exfiltration Over C2 Channel	Small archive of routing configuration and application logs likely transferred over the C2 channel.	Archive staging plus outbound HTTPS; no bulk customer data observed.	Data-loss assessment, proxy logs, archive artifacts.
Impact (TA0040)	T1565.001 - Stored Data Manipulation T1489 - Service Stop T1499 - Endpoint Denial of Service	Routing profile manipulated and route adapter service stopped, degrading ATM authorization and causing timeouts/duplicate holds.	Config hash mismatch; service stop event; national timeout spike.	Config integrity monitoring, service control alerts, transaction failure thresholds.

Techniques intentionally not asserted

- No ransomware encryption is asserted because systems are not encrypted in the scenario.
- No destructive data wiping is asserted because the impact comes from configuration manipulation and service disruption.
- No customer account compromise is asserted because core banking access and customer credentials are not evidenced.
- No bulk customer PII exfiltration is asserted; only configuration and logs are included in the exercise evidence.

Controls to validate after the exercise

- Third-party account lifecycle, MFA, conditional access, vendor session approval, and out-of-band verification.
- PAM coverage for all switch service and administrator accounts.
- Admin jump-host hardening, egress restrictions, EDR tamper protection, and central logging.

- Switch configuration baseline, code/config signing, drift detection, and dual-approval rollback.
- Transaction monitoring that correlates customer impact with configuration and cyber telemetry.
- Processor and vendor contact trees with 24/7 escalation and incident evidence exchange.

14. SOURCE TRACEABILITY

14. Source Traceability

This revised tabletop exercise was generated from the uploaded ATM Switch Outage and Cash Access Disruption TTX and the uploaded evaluation feedback. The evaluation's strongest improvement request was to replace speculative cyber references with an explicit, end-to-end, evidence-supported adversary path and technique-level ATT&CK mapping.

Inputs used

Input	How it was used
Uploaded ATM Switch Outage TTX PDF	Preserved the business scenario: national ATM failures, duplicate debit holds, branch overflow, holiday cash demand, processor dependency, public trust, restoration, and post-incident obligations.
Uploaded evaluation JSON	Integrated recommendations around realism, coherence, cyber accuracy, technical evidence, concrete adversary path, containment constraints, and evidence-based ATT&CK mapping.
Sample TTX structures available in workspace	Informed facilitation style, objectives, rules of engagement, inject/debrief format, and professional tabletop pacing.
MITRE ATT&CK Enterprise	Used to validate technique names and IDs for the final ATT&CK mapping.

Facilitator customization checklist

- Replace generic bank, vendor, processor, system, and regulator names with approved internal names.
- Adjust incident severity labels to match the organization's taxonomy.
- Confirm actual ATM switch architecture, monitoring tools, vendor access paths, PAM process, and DR model.
- Align regulator references with the organization's jurisdictions and reporting procedures.
- Pre-approve customer, branch, contact-center, and media statements before a live exercise.
- Decide whether to include or remove technical artifacts depending on audience maturity.

End of exercise package

The exercise is ready for facilitation after local names, severity labels, contact trees, and jurisdiction-specific notification references are inserted.